

File No.: EXP202203970

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Ms. B.B.B. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on February 27, 2022. The complaint is directed against NORDETIA CLINICS MÓSTOLES S.L. with NIF B80923279 (hereinafter, NORDETIA). The reasons for the complaint are as follows: On February 27, 2022, the complainant stated that she received an email from the NORDETIA clinic in Móstoles that included the email addresses of 21 recipients; as the email was sent without using the blind carbon copy functionality.

Along with the notification, a copy of the email related to a closure communication from the clinic, sent to 21 recipients without the blind carbon copy option, is provided.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), this complaint was forwarded to NORDETIA for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on April 17, 2022, as evidenced by the certificate in the file.

However, no response has been received to this forwarding letter.

THIRD: On May 27, 2022, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: The General Sub-Directorate for Data Inspection proceeded to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

On August 24, 2022, a request for information was sent to the defendant party to explain, among other matters, the reason why the email was sent without blind carbon copy (showing the addresses of the other recipients to all of them) and the reason why the breach has not been reported to the Spanish Agency for Data Protection.

Notified to the defendant party on August 30, 2022, via the electronic notification system Notific@, and after the response period had elapsed without receiving a written statement from this Agency, the request was reiterated by postal services, with this notification being delivered at the office on October 14, 2022, at 12:11.

As of today, no written statement has been received from the complainant.

Volume of the treatments carried out: 21 affected in the reported breach.

FIFTH: On April 4, 2023, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the defendant party for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR, respectively.

SIXTH: Notification of this agreement was attempted to the defendant party on April 4, 2023, via the electronic notification system Notific@, and after the response period had elapsed without receiving a written statement from this Agency, the notification was reiterated by postal services, being returned as unknown on May 11 of the same year.

SEVENTH: The aforementioned initiation agreement was notified through an announcement published in the "Official State Gazette," in accordance with the provisions of Article 44 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP),

and after the period granted for the submission of allegations had elapsed, it has been confirmed that no allegations have been received from the defendant party.

Article 64.2.f) of the LPACAP - a provision of which the defendant party was informed in the initiation agreement - establishes that if no allegations are made within the stipulated period regarding the content of the initiation agreement, when it contains a precise statement regarding the responsibility attributed, it may be considered a proposal for resolution. In this case, the initiation agreement of the sanctioning file determined the facts on which the accusation was based, the infringement of the GDPR attributed to the defendant, and the sanction that could be imposed. Therefore, considering that the defendant party has not made allegations against the initiation agreement of the file and in accordance with the provisions of Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case as a proposal for resolution.

In light of all that has been acted upon, the Spanish Agency for Data Protection considers the following facts proven in the present procedure,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/8

PROVEN FACTS

FIRST: It has been established in the file that, on February 27, 2022, the claimant received an email from the clinic NORDETIA CLINICS MÓSTOLES S.L.

SECOND: It is recorded in the file that the aforementioned email included the email addresses of 21 recipients; as the email was sent without using the blind carbon copy functionality.

LEGAL GROUNDS

I

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Article 5.1.f) of the GDPR

Article 5.1.f) "Principles relating to processing" of the GDPR establishes:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by means of appropriate technical or organizational measures ('integrity and confidentiality')."

In this case, it has been established that there has been unauthorized access to the email addresses of the 21 recipients, violating the principle of confidentiality, as an email was sent in which all the email addresses of the 21 recipients could be seen in the non-hidden copy.

III

Classification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000

EUR or, in the case of an undertaking, an amount equivalent to up to 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that:

"Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, infringements that constitute a substantial violation of the articles mentioned therein are considered very serious and shall be subject to a three-year statute of limitations, particularly the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

IV

Sanction for the infringement of Article 5.1.f) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is appropriate to graduate the sanction to be imposed in accordance with the criteria established in Article 83.2 of the GDPR.

Furthermore, it is considered appropriate to graduate the sanction to be imposed in accordance with the criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/8

From the balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 5.1.f) of the GDPR, a sanction of €1,000 (ONE THOUSAND EUROS) can be established.

V

Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.” In this case, at the time the breach occurred, it is evident that NORDETIA lacked reasonable security measures based on the estimated potential risks, as well as that the information and training directed at the staff who were to carry out the processing of personal data were entirely insufficient, specifically regarding the sending of emails.

VI

Classification of the infringement of Article 32 of the GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/8

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total global annual turnover of the preceding financial year, opting for the higher amount:

5) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a limitation period of two years:

...

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

VII

Sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is appropriate to graduate the sanction to be imposed in accordance with the criteria established in Article 83.2 of the GDPR.

It is also considered appropriate to graduate the sanction to be imposed in accordance with the criteria established in paragraph 2 of Article 76 “Sanctions and corrective measures” of the LOPDGDD.

From the balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 5.1.f) of the GDPR, a sanction of €500 (FIVE HUNDRED EUROS) can be established.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/8

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on NORDETIA CLINICS MÓSTOLES S.L., with NIF B80923279, for an infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, a fine of ONE

THOUSAND EUROS (€1,000).

TO IMPOSE on NORDETIA CLINICS MÓSTOLES S.L., with NIF B80923279, for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, a fine of FIVE HUNDRED EUROS (€500).

SECOND: TO NOTIFY this resolution to NORDETIA CLINICS MÓSTOLES S.L.

THIRD: To warn the sanctioned party that they must pay the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not receive knowledge of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered concluded.

938-181022

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es